LAPORAN WORKSHOP & DOKUMEN RANCANGAN REST API (v1)

Mata Kuliah: Pemrograman Web Service (Minggu ke-4) | **Dosen Pengampu:** Zaenul Arif, S.Kom., M.Kom.
Topik: REST API Design: Resource, Endpoint, CRUD, Filtering, Pagination | **Milestone:** M2 – API Blueprint
Platform: SportVenue — Platform Web Service Booking Lapangan Olahraga Online

Identitas Kelompok:	**Kelompok 3 (Kelas TI - Universitas Harkat Negeri 2026/2027)**	**Base URL API:**	http://localhost:8000/api/v1
Anggota & Peran:	1. Moh. Arif Prasetyo (23215043) — *Availability Engine & Discovery* 2. Muhamad Djafar Ilyasa (23215028) — *Auth & User Security* 3. Lutfi Laeli Nur Afiyah (23215046) — *Core Booking & Concurrency Lock* 4. Muh. Kharis Maulana Elhaq (23215059) — *Payment Gateway & Webhook*	**Spesifikasi Desain:**	• Standar: RESTful JSON API • Autentikasi: Sanctum Bearer Token • Versioning: Path-based (/api/v1) • Konvensi: English (Plural, Kebab-case)

20.1 Aktivitas 1 – Pemodelan Resource (Tersinkronisasi Penuh dengan ERD)

Resource diturunkan secara presisi dari entitas bisnis SportVenue (Modul Ajar Point 9.3: *Resource tidak harus sama dengan tabel*). Kolom fisik database dan atribut virtual turunan telah diselaraskan 100% dengan ERD aplikasi:

No	Resource URI (Jamak)	Tabel DB	Atribut Fisik Database & Field Turunan	Relasi Antar Resource	Jenis Resource
1	**users**	users	id, name, email, phone, password, role, status, email_verified_at, created_at	1 : N ke venues (pengelola) 1 : N ke bookings (penyewa)	Collection
2	**venues**	venues	id, owner_id, name, slug, description, address, city, phone, dp_percent, cancel_free_hours, cancel_refund_percent, image_url	N : 1 ke users (owner) 1 : N ke courts	Collection
3	**courts**	courts	id, venue_id, name, sport_type, is_active, created_at	N : 1 ke venues 1 : N ke prices, operating-hours, blocks, bookings	Sub-resource / Collection
4	**prices**	court_prices	id, court_id, day_type, start_time, end_time, price, created_at	N : 1 ke courts	Sub-resource
5	**operating-hours**	operating_hours	id, court_id, day_of_week, open_time, close_time, slot_duration_minutes	N : 1 ke courts	Sub-resource
6	**blocks**	schedule_blocks	id, court_id, start_at, end_at, reason, created_at	N : 1 ke courts	Sub-resource
7	**availability**	*(Kalkulasi)*	court_id, play_date, slots [slot_time, status, price] *(Dihasilkan dari jam operasional, blokir, dan slot terisi)*	Turunan dari courts (kalkulasi slot terisi & blokir)	Sub-resource (Virtual / Read-Only)
8	**bookings**	bookings	id, code, user_id, court_id, total_price, dp_amount, status, expires_at, cancelled_at, refund_amount *(Tgl main diturunkan dari booking_slots.slot_start)*	N : 1 ke users, N : 1 ke courts 1 : N ke booking_slots, 1 : N ke payments	Collection
9	**payments**	payments	id, booking_id, order_id, type, amount, status, payment_type, snap_token, snap_redirect_url, paid_at	N : 1 ke bookings	Sub-resource / Collection
10	**booking_slots**	booking_slots	id, booking_id, court_id, slot_start, slot_end, price, created_at	N : 1 ke bookings unique(court_id, slot_start)	Internal Engine (Anti Double Booking)
11	**me**	users	id, name, email, phone, role, status	N/A (merujuk ke pengguna login aktif)	Singleton

Diagram Relasi Antar-Resource (ERD Ringkas):

```
+-------------+ 1 N +-------------+ 1 N +-------------+ 1 N +-----------------+ | users | --------> | venues | --------> | courts | --------> | prices (prices) | +-------------+ +-------------+ +-------------+ +-----------------+ | 1 | 1 1 N +-----------------+ | | --------+------> | operating-hours | | | 1 | +-----------------+ | | --------+------> | blocks (blocks) | | | +-----------------+ v N v N +-------------+ 1 N +-----------------+ | bookings | ------------------------------> | booking_slots | (Unique Index: anti collision) +-------------+ +-----------------+ | 1 v N +-------------+ | payments | (Midtrans Snap Token & Webhook Callback Idempotent) +-------------+
```

Catatan Penyelarasan Atribut Fisik Database vs Field Turunan:

- **venues.is_active:** Status aktif dikontrol di tingkat lapangan (courts.is_active). Venue tidak memiliki kolom is_active.
- **play_date:** Tidak ada kolom play_date di tabel bookings; tanggal main tersimpan di baris slot booking_slots.slot_start.
- **Detail courts:** Lapangan hanya memuat name, sport_type, is_active. Foto fasilitas berada di venues.image_url.
- **starting_price:** Field virtual dinamis hasil agregasi MIN(court_prices.price), bukan kolom fisik tabel venues.

20.2 Aktivitas 2 – Endpoint Matrix (20 menit)

Disusun 26 endpoint RESTful yang selaras 100% dengan resource dan model database SportVenue. Setiap baris memuat HTTP method semantik, path URI terstandar, fungsi operasi bisnis, aktor pengguna, serta status sukses dan status gagal yang relevan:

No	Method	Endpoint (Base: /api/v1)	Fungsi & Operasi Bisnis	Aktor	Sukses	Status Gagal Relevan
1	POST	/auth/register	Registrasi pengguna baru (penyewa aktif, pengelola pending)	Publik	**201 Created**	400, 422
2	POST	/auth/login	Autentikasi akun & penerbitan Sanctum Bearer Token	Publik	**200 OK**	401, 422
3	POST	/auth/logout	Revokasi token autentikasi aktif pengguna	Login	**204 No Content**	401
4	GET	/me	Mengambil profil pengguna yang sedang login (singleton)	Login	**200 OK**	401
5	GET	/venues	Katalog venue mitra dengan filter city, sport, min/max price, search	Publik	**200 OK**	400, 422
6	GET	/venues/{id}	Detail satu venue beserta daftar fasilitas lapangan fisiknya	Publik	**200 OK**	404
7	GET	/venues/{id}/courts	Daftar lapangan pada venue tertentu (sub-resource)	Publik	**200 OK**	404
8	GET	/courts/{id}	Detail lapangan fisik (nama, cabang olahraga, status is_active, relasi harga)	Publik	**200 OK**	404
9	GET	/courts/{id}/prices	Daftar struktur harga sewa lapangan (reguler, peak, weekend)	Publik	**200 OK**	404
10	GET	/courts/{id}/operating-hours	Daftar jam buka-tutup operasional lapangan seminggu penuh	Publik	**200 OK**	404
11	GET	/courts/{id}/availability	Matriks ketersediaan slot jam & tarif per tanggal (YYYY-MM-DD)	Publik	**200 OK**	404, 422
12	POST	/bookings	Reservasi booking baru, kunci slot atomik, hold DP 15 menit	Penyewa	**201 Created**	400, 409, 422
13	GET	/bookings	Riwayat transaksi booking milik penyewa yang sedang login	Penyewa	**200 OK**	401
14	GET	/bookings/{id}	Detail faktur booking, slot yang diambil, dan rincian bayar	Penyewa, Pengelola	**200 OK**	401, 403, 404
15	POST	/bookings/{id}/payments	Membuat transaksi DP Midtrans Snap token & redirect URL	Penyewa	**201 Created**	401, 403, 409
16	POST	/bookings/{id}/cancellation	Membatalkan booking & hitung refund otomatis kebijakan venue	Penyewa	**200 OK**	401, 403, 409
17	POST	/payments/webhook/midtrans	Callback webhook notifikasi gateway (verifikasi HMAC SHA-512)	Midtrans	**200 OK**	401, 403
18	POST	/manage/venues	Mendaftarkan venue baru milik mitra pengelola	Pengelola	**201 Created**	401, 403, 422
19	PUT	/manage/venues/{id}	Memperbarui profil venue secara menyeluruh (alamat, kebijakan DP/refund)	Pengelola	**200 OK**	401, 403, 404, 422
20	DELETE	/manage/venues/{id}	Menghapus/menonaktifkan venue dari platform	Pengelola	**204 No Content**	401, 403, 404, 409
21	POST	/manage/courts	Menambah lapangan baru pada venue milik pengelola	Pengelola	**201 Created**	401, 403, 422
22	PUT	/manage/courts/{id}	Memperbarui data lapangan fisik secara menyeluruh	Pengelola	**200 OK**	401, 403, 404, 422
23	PATCH	/manage/courts/{id}	Mengubah status aktif/non-aktif lapangan parsial (is_active)	Pengelola	**200 OK**	401, 403, 404
24	DELETE	/manage/courts/{id}	Menghapus/menonaktifkan lapangan fisik dari sistem	Pengelola	**204 No Content**	401, 403, 404, 409
25	POST	/manage/prices	Menambahkan aturan konfigurasi tarif sewa lapangan	Pengelola	**201 Created**	401, 403, 422
26	DELETE	/manage/prices/{id}	Menghapus aturan konfigurasi tarif sewa	Pengelola	**204 No Content**	401, 403, 404
27	POST	/manage/blocks	Membuat jadwal pemblokiran slot perawatan/turnamen	Pengelola	**201 Created**	401, 403, 422
28	DELETE	/manage/blocks/{id}	Membatalkan jadwal pemblokiran lapangan fisik	Pengelola	**204 No Content**	401, 403, 404
29	PATCH	/manage/bookings/{id}/status	Mengubah status sewa menjadi COMPLETED / NO_SHOW	Pengelola	**200 OK**	401, 403, 422
30	GET	/admin/users	Daftar seluruh akun pengguna platform (filter role & status)	Admin	**200 OK**	401, 403
31	PATCH	/admin/users/{id}/verify	Verifikasi dan aktivasi kemitraan akun pengelola baru	Admin	**200 OK**	401, 403, 404

20.3 Aktivitas 3 – Desain Query untuk Endpoint Collection (15 menit)

Ditetapkan query parameter standar pada 3 endpoint collection utama untuk menyaring (*filter*), mencari (*search*), mengurutkan (*sort*), dan memaginasi (*pagination*) dengan whitelist yang selaras dengan skema database:

Endpoint Collection	Filter (Whitelist)	Search	Sort (Default & Whitelist)	Pagination (Default / Maks)
GET /venues /api/v1/venues	• city (string) • sport / sport_type (futsal, badminton, basket, mini_soccer) • min_price, max_price *(Filter olahraga & harga dievaluasi via relasi courts.courtPrices)*	q (mencari pada name, address, city)	• Default: name • Whitelist: name, -name, created_at, -created_at, starting_price*, -starting_price* *(*Ket: starting_price diurutkan via subquery agregasi MIN(court_prices.price))*	Model: Offset-based Param: page, per_page • Default: **10** • Maksimum: **50**
GET /bookings /api/v1/bookings	• status (PENDING_PAYMENT, CONFIRMED, COMPLETED, CANCELLED, EXPIRED, NO_SHOW) • court_id (integer) • date_from, date_to *(Filter rentang tgl dievaluasi via booking_slots.slot_start)*	q (mencari kode booking: code, misal BK-20261011)	• Default: -created_at • Whitelist: created_at, -created_at, total_price, -total_price, expires_at, -expires_at	Model: Offset-based Param: page, per_page • Default: **15** • Maksimum: **100**
GET /admin/users /api/v1/admin/users	• role (penyewa, pengelola, admin) • status (active, pending, suspended)	q (mencari pada name, email, phone)	• Default: -created_at • Whitelist: name, -name, email, created_at, -created_at	Model: Offset-based Param: page, per_page • Default: **20** • Maksimum: **100**

20.4 Aktivitas 4 – Peer Review & Quality Checklist (10 menit)

Evaluasi kelayakan kontrak rancangan API SportVenue mengacu pada 8 butir standar industri perancangan RESTful API:

No	Butir Pemeriksaan Kualitas Desain REST API	Status	Catatan Evaluasi Kelompok & Hasil Penilaian
1	Semua URI memakai kata benda jamak, huruf kecil, dan tanpa kata kerja	**[X] Ya**	Seluruh endpoint memakai kata benda jamak (/venues, /courts, /prices, /blocks, /bookings, /payments). Tidak ada kata kerja seperti /getVenues.
2	Prefix /api/v1 dipakai konsisten	**[X] Ya**	Seluruh URI diawali prefix /api/v1, memastikan evolusi API tanpa memutus (*breaking*) integrasi client lama.
3	Method sesuai operasi; GET tidak mengubah data	**[X] Ya**	Operasi GET bersifat *safe & idempotent* (hanya membaca data). Seluruh mutasi state wajib memakai POST (create), PUT/PATCH (update), atau DELETE.
4	POST → 201, DELETE → 204, dan status gagal relevan dicantumkan	**[X] Ya**	Create menghasilkan 201 Created disertai header Location; Delete menghasilkan 204 No Content. Status gagal (400, 401, 403, 404, 409, 422) didefinisikan lengkap.
5	Nesting maksimal 2 tingkat	**[X] Ya**	Nesting dibatasi: /venues/{id}/courts, /courts/{id}/prices. Setelah item memiliki ID unik global, akses dilakukan secara flat: /courts/{id}, /bookings/{id}.
6	Setiap collection memiliki pagination dengan batas maksimum	**[X] Ya**	Setiap collection dibatasi default 10–20 dan hard-cap max 50–100 untuk menangkal celah OWASP *Unrestricted Resource Consumption*.
7	Filter/sort memakai query parameter dengan whitelist	**[X] Ya**	Filter dan sort dioperasikan di query string dengan whitelist ketat yang selaras kolom fisik ERD untuk mencegah SQL error atau kebocoran kolom sensitif.
8	Format error seragam	**[X] Ya**	Seluruh skenario kegagalan memakai amplop format seragam: { status: 'error', message: '...', errors: { ... } }.

Tindak Lanjut Perbaikan Pasca Review & Masukan Penyelarasan ERD:
1. **Penyelarasan Kolom play_date:** Dihapus dari whitelist sort tabel bookings dan dicatat secara transparan sebagai nilai relasional dari booking_slots.slot_start.
2. **Penyelarasan venues.is_active:** Dihilangkan dari atribut tabel venues dan filter GET /venues, karena keaktifan diatur di level lapangan courts.is_active.
3. **Deskripsi Detail Lapangan:** Disesuaikan tepat dengan kolom fisik courts (nama, cabang olahraga, status aktif); foto berada di venues.image_url.
4. **Klarifikasi starting_price:** Dicatat secara eksplisit bahwa starting_price adalah nilai turunan / field virtual agregasi MIN(court_prices.price).
5. **Validasi & Keamanan:** Validasi format YYYY-MM-DD pada availability serta pencegahan OWASP API3 (menghilangkan password/remember_token).

Kamus & Panduan Lengkap HTTP Status Code Handling (RFC 9110)

Setiap kode status HTTP yang dipakai dalam perancangan REST API SportVenue memiliki semantik baku, kondisi penggunaan spesifik, dan format body response terstandar:

Kode HTTP	Kategori	Arti & Semantik Standar (RFC 9110)	Konteks Penggunaan pada SportVenue	Karakteristik Body Response
200 OK	2xx Success	Request berhasil diproses dan mengembalikan data.	GET katalog venue/court/booking, PUT/PATCH update, POST kalkulasi refund batal.	Amplop: { status: 'success', data: { ... } }
201 Created	2xx Success	Resource baru berhasil dibuat di server.	POST register user, POST booking baru, POST tambah lapangan, POST token DP Snap.	Memuat data baru & header Location: /api/v1/...
204 No Content	2xx Success	Operasi tuntas, sengaja tanpa konten response.	DELETE lapangan, DELETE jadwal blokir, POST logout revokasi token.	**Tanpa Body** (0 byte payload jaringan)
400 Bad Request	4xx Client	Sintaks request rusak / gagal diparse.	Payload JSON malformed (kurung kurawal tidak tertutup, koma menggantung).	Amplop: { status: 'error', message: 'Malformed JSON' }
401 Unauthorized	4xx Client	Kredensial autentikasi tidak ada / tidak valid.	Akses tanpa token Bearer, token Sanctum expired, kombinasi login salah.	Pesan: Unauthenticated / Invalid credentials
403 Forbidden	4xx Client	Identitas dikenali, tetapi tidak punya izin akses.	Penyewa akses /manage/*, edit venue milik orang lain, HMAC webhook palsu.	Pesan: Akses ditolak. Tidak berhak atas aksi ini.
404 Not Found	4xx Client	Resource yang diminta tidak ada di sistem.	Akses /venues/999 atau /courts/888 dengan ID yang tidak terdaftar di DB.	Amplop: { status: 'error', message: 'Not Found' }
409 Conflict	4xx Client	Bentrok dengan state database saat ini.	**Anti Double Booking Guard (§9.2):** Slot di-hold user lain; booking expired dibatalkan.	Amplop: { code: 'SLOT_ALREADY_LOCKED', ... }
422 Unprocessable	4xx Client	Sintaks benar, isi melanggar validasi bisnis.	Form booking tanpa slot, format tgl bukan YYYY-MM-DD, email duplikat, DP < 10%.	Amplop: { errors: { field: ['detail pesan'] } }
429 Too Many Req	4xx Client	Frekuensi request melebihi ambang batas.	Spamming booking, brute-force login (> 60 request/menit). Menangkal bot.	Header Retry-After: 60 + pesan rate limit.
500 Server Error	5xx Server	Kegagalan tak terduga pada server backend.	Koneksi MySQL terputus, fatal exception runtime unhandled.	Pesan umum, **tanpa stack trace** demi keamanan.
503 Unavailable	5xx Server	Layanan upstream/gateway sedang down.	API Midtrans payment gateway down/maintenance saat generate token Snap.	Pesan petunjuk gateway sibuk, coba kembali.

Prinsip & Analisis Penanganan Status Code Kritis:

1. **Mengapa Double Booking menggunakan 409 Conflict (bukan 400 atau 422)?**
Request penyewa valid secara sintaks dan tipe data (lolos 422). Namun operasi ditolak karena terjadi tabrakan konkurensi pada indeks unik (court_id, slot_start) di InnoDB. Sesuai RFC 9110, 409 Conflict adalah status paling tepat untuk bentrok state data.

2. **Perbedaan Tegas 401 Unauthorized vs 403 Forbidden:**
• **401 (Autentikasi):** Masalah identitas (token tidak ada/kedaluwarsa). Client dapat mengulang request dengan menyertakan token yang valid.
• **403 (Otorisasi):** Identitas sah, tetapi role/policy melarang aksi tersebut (misal penyewa menghapus court). Mengulang token tidak akan berhasil.

3. **Mengapa Validasi Form menghasilkan 422 Unprocessable Content (bukan 400)?**
Membedakan kesalahan transport/JSON corrupt (400) dengan kegagalan aturan bisnis domain (422), memudahkan frontend memetakan error per field.

4. **Semantik 201 Created vs 204 No Content:**
201 wajib menyertakan header Location dan representasi data baru; 204 digunakan saat delete/logout tanpa mengembalikan body.

Representasi Response JSON & Format Error Terstandar

Format representasi data keluaran Laravel API Resource seragam untuk seluruh endpoint (envelope data, meta, dan links):

Response Item Tunggal & Error Validasi 422:

```
// 1. Response Item Tunggal (GET /api/v1/venues/1) { "status": "success", "data": { "id": 1, "name": "Arena Garuda Futsal", "slug": "arena-garuda-futsal", "description": "Gelanggang futsal berstandar nasional", "address": "Jl. Martoloyo No. 12", "city": "Tegal", "phone": "081234567890", "dp_percent": 30, "cancel_free_hours": 24, "cancel_refund_percent": 50, "image_url": "https://sportvenue.test/storage/venues/garuda.jpg" } } // 2. Response Validasi Gagal (422 Unprocessable Content) { "status": "error", "message": "Data yang dikirim tidak valid.", "errors": { "slots": ["Minimal satu slot jam harus dipilih."] } }
```

Response Koleksi Pagination & Conflict 409:

```
// 3. Response Koleksi dengan Pagination (GET /venues) { "status": "success", "data": [ { "id": 1, "name": "Arena Garuda Futsal", "city": "Tegal", "starting_price": 120000 }, { "id": 2, "name": "GOR Satria Badminton", "city": "Tegal", "starting_price": 40000 } ], "links": { "first": "http://localhost:8000/api/v1/venues?page=1", "last": "http://localhost:8000/api/v1/venues?page=3", "prev": null, "next": "http://localhost:8000/api/v1/venues?page=2" }, "meta": { "current_page": 1, "per_page": 2, "total": 6, "last_page": 3 } } // 4. Response Aturan Bisnis Bentrok Slot (409 Conflict) { "status": "error", "message": "Satu atau lebih slot sudah terisi atau sedang di-hold. Silakan pilih slot lain.", "code": "SLOT_ALREADY_LOCKED" }
```

Pola Aksi Non-CRUD & Catatan Keputusan Desain Arsitektur

• **Aksi Non-CRUD Pembatalan Booking (POST /bookings/{id}/cancellation):** Dimodelkan menggunakan pola *Sub-resource / Process as Resource*. Pembatalan sewa lapangan bukan sekadar PATCH status = cancelled, melainkan memerlukan evaluasi audit trail kebijakan pembatalan venue (perhitungan tenggat waktu H-24/H-12, persentase refund DP, pelepasan kunci baris slot operasional di database, dan notifikasi refund ke penyewa).
• **Aksi Non-CRUD Pembayaran DP (POST /bookings/{id}/payments):** Dipisahkan menjadi sub-resource pembayaran karena memiliki entitas data mandiri (order_id Midtrans, status token Snap, redirect URL, dan verifikasi callback webhook idempotent).
• **Dukungan PUT vs PATCH:** Keduanya didukung pada endpoint /manage/courts/{id} dan /manage/venues/{id}. PUT menggantikan seluruh representasi data lapangan, sedangkan PATCH dipergunakan untuk pembaruan atribut tunggal secara atomik (misalnya mengubah status aktif/non-aktif lapangan is_active).
• **Strategi Versioning:** Menggunakan path-based versioning (/api/v1) yang mudah dipahami, mudah diuji via Postman, dan secara transparan memisahkan kontrak versi lama jika di kemudian hari dilakukan breaking change.
• **Struktur Envelope Data & Pagination:** Menggunakan format { status, data, links, meta } yang selaras dengan keluaran standar Laravel Eloquent API Resource, mempermudah tim frontend/mobile dalam rendering navigasi halaman.